TryHackMe | Linux Privilege E

tryhackme.com/room/linprivesc

Room completed (100%)

You have gained SSH access to a large scientific facility. Try to elevate your privileges until you are Root.
We designed this room to help you build a thorough methodology for Linux privilege escalation that will be very useful in exams such as OSCP and your penetration testing engagements.

Leave no privilege escalation vector unexplored, privilege escalation is often more an art than a science.

You can access the target machine over your browser or use the SSH credentials below.

- Username: leonard
- Password: Penny123

Answer the questions below

What is the content of the flag1.txt file?

THM-42828719920544

✓ Correct Answer

What is the content of the flag2.txt file?

THM-168824782390238

✓ Correct Answer

How likely are you to recommend this room to others?

1 2 3 4 5 6 7 8 9 10

Submit now

TryHackMe | Linux Privilege E

tryhackme.com/room/linprivesc

Room completed (100%)

```
alper@targetsystem:/backups$ id
uid=1000(alper) gid=1000(alper) groups=1000(alper),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),120(lpadmin),131(lxd),132(sambashare)
alper@targetsystem:/backups$ whoami
alper
alper@targetsystem:/backups$ ls -l
total 24
-rwsr-sr-x 1 root root 16712 Jun 17 16:24 nfs
-rw-r--r-- 1 root root    76 Jun 17 16:24 nfs.c
alper@targetsystem:/backups$ ./nfs
root@targetsystem:/backups# id
uid=0(root) gid=0(root) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),120(lpadmin),131(lxd),132(sambashare),1000(alper)
root@targetsystem:/backups# whoami
root
root@targetsystem:/backups#
```

Notice the nfs executable has the SUID bit set on the target system and runs with root privileges.

Answer the questions below

How many mountable shares can you identify on the target system?

3 — ✓ Correct Answer

How many shares have the "no_root_squash" option enabled?

3 — ✓ Correct Answer

Gain a root shell on the target system

No answer needed — ✓ Correct Answer

What is the content of the flag7.txt file?

THM-89384012 — ✓ Correct Answer

Room completed (100%)

```
alper@targetsystem:~/Desktop$ ./path
root@targetsystem:~/Desktop# whoami
root
root@targetsystem:~/Desktop# id
uid=0(root) gid=0(root) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),120(lpadmin),131(lxd),132(sambashare),1000(alper)
root@targetsystem:~/Desktop#
```

Answer the questions below

What is the odd folder you have write access for?

/home/murdoch

✓ Correct Answer

Exploit the $PATH vulnerability to read the content of the flag6.txt file.

No answer needed

✓ Correct Answer

What is the content of the flag6.txt file?

THM-736628929

✓ Correct Answer

Task 11 Privilege Escalation: NFS

Task 12 Capstone Challenge

How likely are you to recommend this room to others?

1 2 3 4 5 6 7 8 9 10

The incoming reverse shell connection has root privileges:

```
┌──(root💀 TryHackMe)-[~]
└─# nc -nlvp 7777
listening on [any] 7777 ...
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.12] 59838
bash: cannot set terminal process group (7275): Inappropriate ioctl for device
bash: no job control in this shell
root@targetsystem:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@targetsystem:~# whoami
whoami
root
root@targetsystem:~#
```

In the odd event you find an existing script or task attached to a cron job, it is always worth spending time to understand the function of the script and how any tool is used within the context. For example, tar, 7z, rsync, etc., can be exploited using their wildcard feature.

Answer the questions below

How many user-defined cron jobs can you see on the target system?

4 ✓ Correct Answer

What is the content of the flag5.txt file?

THM-383000283 ✓ Correct Answer

What is Matt's password?

123456 ✓ Correct Answer

Task 10 ✓ Privilege Escalation: PATH

This will launch a root shell as seen below;

```
Erase is control-H (^H).
# id
uid=0(root) gid=1000(alper) groups=1000(alper),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),120(lpadmin),131(lxd),132(sambashare)
#
```

Answer the questions below

Complete the task described above on the target system

No answer needed — ✓ Correct Answer

How many binaries have set capabilities?

6 — ✓ Correct Answer

What other binary can be used through its capabilities?

view — ✓ Correct Answer

What is the content of the flag4.txt file?

THM-9349843 — ✓ Correct Answer

Task 9 Privilege Escalation: Cron Jobs

Task 10 Privilege Escalation: PATH

```
user@debian:~$ su hacker
Password:
root@debian:/home/user# id
uid=0(root) gid=0(root) groups=0(root)
root@debian:/home/user# whoami
root
root@debian:/home/user#
```

Now it's your turn to use the skills you were just taught to find a vulnerable binary.

Answer the questions below

Which user shares the name of a great comic book writer?

gerryconway — ✓ Correct Answer

What is the password of user2?

Password1 — ✓ Correct Answer

What is the content of the flag3.txt file?

THM-3847834 — ✓ Correct Answer

Task 8 ✓ Privilege Escalation: Capabilities

Task 9 ✓ Privilege Escalation: Cron Jobs

Task 10 ✓ Privilege Escalation: PATH

TryHackMe | Linux Privilege E

tryhackme.com/room/linprivesc

Room completed (100%)

Answer the questions below

How many programs can the user "karen" run on the target system with sudo rights?

3 ✓ Correct Answer

What is the content of the flag2.txt file?

THM-402028394 ✓ Correct Answer

How would you use Nmap to spawn a root shell if your user had sudo rights on nmap?

sudo nmap --interactive ✓ Correct Answer

What is the hash of frank's password?

$6$2.sUUDsOLIpXKxcr$eImtgFExyr2ls4jsghdD3DHLHHP9X50Iv.jNmwo/BJpphrPRJWjelWEz2HH.joV14aDEwW1c3CahzB1uaq ✓ Correct Answer

Task 7 Privilege Escalation: SUID

Task 8 Privilege Escalation: Capabilities

Task 9 Privilege Escalation: Cron Jobs

Task 10 Privilege Escalation: PATH

1. Based on your findings, you can use Google to search for an existing exploit code.
2. Sources such as https://www.cvedetails.com/ can also be useful.
3. Another alternative would be to use a script like LES (Linux Exploit Suggester) but remember that these tools can generate false positives (report a kernel vulnerability that does not affect the target system) or false negatives (not report any kernel vulnerabilities although the kernel is vulnerable).

Hints/Notes:

1. Being too specific about the kernel version when searching for exploits on Google, Exploit-db, or searchsploit
2. Be sure you understand how the exploit code works BEFORE you launch it. Some exploit codes can make changes on the operating system that would make them unsecured in further use or make irreversible changes to the system, creating problems later. Of course, these may not be great concerns within a lab or CTF environment, but these are absolute no-nos during a real penetration testing engagement.
3. Some exploits may require further interaction once they are run. Read all comments and instructions provided with the exploit code.
4. You can transfer the exploit code from your machine to the target system using the `SimpleHTTPServer` Python module and `wget` respectively.

Answer the questions below

find and use the appropriate kernel exploit to gain root privileges on the target system.

No answer needed

✓ Correct Answer

What is the content of the flag1.txt file?

THM-28392872729920

✓ Correct Answer

Task 6 Privilege Escalation: Sudo

Task 7 Privilege Escalation: SUID

Task 8 Privilege Escalation: Capabilities

Room completed (100%)

As we are in the Linux realm, familiarity with Linux commands, in general, will be very useful. Please spend some time getting comfortable with commands such as `find`, `locate`, `grep`, `cut`, `sort`, etc.

Answer the questions below

What is the hostname of the target system?

wade7363 — ✓ Correct Answer

What is the Linux kernel version of the target system?

3.13.0-24-generic — ✓ Correct Answer

What Linux is this?

Ubuntu 14.04 LTS — ✓ Correct Answer

What version of the Python language is installed on the system?

2.7.6 — ✓ Correct Answer

What vulnerability seem to affect the kernel of the target system? (Enter a CVE number)

CVE-2015-1328 — ✓ Correct Answer

Task 4 Automated Enumeration Tools

Task 5 Privilege Escalation: Kernel Exploits